

Security+ 4.5 · Firewalls

Mestre CyberSec — Guia Completo CompTIA Security+ (SY0-701) · **Aula 4.5 — Firewalls (11:31)** · [Vídeo Oficial no YouTube ↗](#) · [Página no Professor Messer ↗](#)

Resumo Executivo da Aula: NGFW: aplicação-aware (vê o tráfego por app); user-aware; threat intel integrado; SSL inspection. UTM = tudo em 1 (pequena empresa). Screened subnet (DMZ) = zona entre internet e interno. Firewall rules: allow/deny/port/protocol/IP.

Highlights que a prova cobra

- NGFW = stateful + app + user + threat intelligence
- Screened subnet (DMZ): zona entre a internet e a rede interna

Dicas de prova & Cenários Típicos

- 'firewall that inspects traffic at the application layer'=NGFW/WAF

Cenário clássico de exame: 'firewall moderno que reconhece apps e aplica regra a usuário'=NGFW.

🔔 Além do Vídeo: O que a CompTIA cobra na prova (Conceitos, Siglas e Armadilhas da Aula 4.5 — Firewalls)

Por que este aprofundamento é cobrado no exame? O vídeo do Professor Messer apresenta uma introdução ágil. Porém, a banca oficial CompTIA Security+ (SY0-701) exige raciocínio de engenharia prática e cobra diretamente os seguintes protocolos, jargões e ferramentas no contexto desta aula:

- **WAF:** Web Application Firewall: Dispositivo ou serviço de segurança que inspeciona o tráfego HTTP/HTTPS na camada de aplicação (Camada 7), filtrando e bloqueando ataques web comuns como SQL Injection, Cross-Site Scripting (XSS) e CSRF.

⚠️ Armadilhas e Pegadinhas Clássicas da Banca:

- Nunca decore apenas letras ou siglas: a CompTIA altera o cenário exigindo que você justifique por que o controle escolhido é o *MAIS adequado* dentre 4 opções válidas.
- Fique atento às restrições do enunciado: 'sem custo adicional' favorece configurações nativas do SO; 'maior granularidade de rede' favorece TACACS+ em vez de RADIUS; 'não-repúdio' exige chave privada/assinatura digital.

✅ Perguntas de treino comentadas (10 questões)

Gabarito com resolução passo a passo e análise técnica individual de cada distrator no fim.
Tente responder antes de olhar.

1. Qual dispositivo de segurança de rede opera na camada de aplicação (Layer 7) e pode inspecionar conteúdo HTTP/HTTPS?

- A) Firewall stateful tradicional
- B) Web Application Firewall (WAF)
- C) Switch Layer 2
- D) Hub

2. Diferença entre IDS e IPS:

- A) IDS detecta e alerta; IPS detecta e BLOQUEIA
- B) São a mesma coisa
- C) IDS é de disco; IPS é de rede
- D) IPS só grava log

3. Sub-rede isolada que expõe servidores públicos (web/email) protegendo a rede interna é a:

- A)** VLAN de voz
- B)** DMZ (screened subnet)
- C)** VPN
- D)** Intranet

4. Cenário corporativo (Firewalls): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 4.5), um analista avalia o seguinte requisito técnico: 'NGFW = stateful + app + user + threat intelligence'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Substituir controles técnicos preventivos por termos de adesão informais
- C)** Implementar a solução correspondente: NGFW = stateful + app + user + threat intelligence...
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

5. Cenário corporativo (Firewalls): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 4.5), um analista avalia o seguinte requisito técnico: 'Screened subnet (DMZ): zona entre a internet e a rede interna'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Implementar a solução correspondente: Screened subnet (DMZ): zona entre a internet e a rede interna...
- B)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- C)** Substituir controles técnicos preventivos por termos de adesão informais
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

6. Cenário corporativo (Firewalls): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 4.5), um analista avalia o seguinte requisito técnico: "firewall that inspects traffic at the application layer"=NGFW/WAF'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Implementar a solução correspondente: 'firewall that inspects traffic at the application layer'=NGFW/WAF...
- B)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- C)** Substituir controles técnicos preventivos por termos de adesão informais
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

7. Cenário corporativo (Firewalls): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 4.5), um analista avalia o seguinte requisito técnico: "firewall moderno que reconhece apps e aplica regra a usuário"=NGFW.'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Substituir controles técnicos preventivos por termos de adesão informais
- C)** Permitir acesso compartilhado entre administradores com credenciais genéricas
- D)** Implementar a solução correspondente: 'firewall moderno que reconhece apps e aplica regra a usuário'=NGFW....

8. Cenário corporativo (Firewalls): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 4.5), um analista avalia o seguinte requisito técnico: 'NGFW = stateful + app + user + threat intelligence'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Substituir controles técnicos preventivos por termos de adesão informais
- C)** Permitir acesso compartilhado entre administradores com credenciais genéricas
- D)** Implementar a solução correspondente: NGFW = stateful + app + user + threat intelligence...

9. Cenário corporativo (Firewalls): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 4.5), um analista avalia o seguinte requisito técnico: 'Screened subnet (DMZ): zona entre a internet e a rede interna'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Substituir controles técnicos preventivos por termos de adesão informais
- C)** Implementar a solução correspondente: Screened subnet (DMZ): zona entre a internet e a rede interna...
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

10. Cenário corporativo (Firewalls): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 4.5), um analista avalia o seguinte requisito técnico: 'firewall that inspects traffic at the application layer'=NGFW/WAF'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Substituir controles técnicos preventivos por termos de adesão informais
- C)** Permitir acesso compartilhado entre administradores com credenciais genéricas
- D)** Implementar a solução correspondente: 'firewall that inspects traffic at the application layer'=NGFW/WAF...

GABARITO COMENTADO COM ANÁLISE DETALHADA DOS DISTRATORES

1) B — Web Application Firewall (WAF).

✓ **Por que está certa:** O **Web Application Firewall (WAF)** é um dispositivo de segurança que opera na camada de aplicação (Layer 7 do modelo OSI) e é projetado para inspecionar o tráfego HTTP/HTTPS, protegendo aplicações web contra ataques como SQL injection, cross-site scripting (XSS), cross-site request forgery (CSRF), entre outros. Ele analisa o conteúdo das requisições e respostas, aplicando regras baseadas em assinaturas ou comportamento anômalo. No syllabus da CompTIA Security+ (SY0-701), o WAF é explicitamente citado como um controle de segurança de camada de aplicação para proteger servidores web. Portanto, é a resposta exata para a descrição.

✗ **Por que as outras estão erradas:**

- *Firewall stateful tradicional:* Um firewall stateful tradicional opera nas camadas de rede e transporte (Layer 3 e 4). Ele mantém uma tabela de estado das conexões e permite ou bloqueia pacotes com base em endereços IP, portas e estado da conexão. No entanto, ele não inspeciona o conteúdo da camada de aplicação (HTTP/HTTPS) e, portanto, não consegue detectar ataques como SQL injection ou XSS. Para inspecionar conteúdo HTTP/HTTPS, seria necessário um firewall de próxima geração (NGFW) com inspeção profunda de pacotes ou um WAF. Logo, o firewall stateful tradicional não atende ao requisito de operar na camada de aplicação e inspecionar conteúdo.
- *Switch Layer 2:* Um switch Layer 2 opera na camada de enlace de dados (Layer 2) e é responsável por encaminhar quadros Ethernet com base em endereços MAC. Ele não possui funcionalidades de inspeção de tráfego em nível de aplicação, muito menos de conteúdo HTTP/HTTPS. Sua função é conectar dispositivos dentro de uma mesma rede local, segmentando domínios de colisão. Não é um dispositivo de segurança de camada 7 e não pode inspecionar conteúdo. Portanto, está incorreto.
- *Hub:* Um hub é um dispositivo de camada física (Layer 1) que simplesmente repete sinais elétricos para todas as portas, sem qualquer inteligência de encaminhamento ou inspeção. Ele não opera em camadas superiores e não oferece nenhuma funcionalidade de segurança, muito menos inspeção de conteúdo HTTP/HTTPS. Hubs são obsoletos e substituídos por switches. Logo, não se aplica ao contexto de segurança de camada de aplicação.

2) A — IDS detecta e alerta; IPS detecta e BLOQUEIA.

✓ **Por que está certa:** A diferença fundamental entre IDS (Intrusion Detection System) e IPS (Intrusion Prevention System) está na ação tomada após a detecção de uma intrusão. O IDS monitora o tráfego de rede ou atividades do sistema em busca de padrões maliciosos e, ao detectar, gera alertas para que administradores possam investigar. Ele é passivo e não interfere no fluxo de dados. O IPS, por sua vez, é ativo: além de detectar, ele bloqueia ou impede a atividade maliciosa em tempo real, descartando pacotes, resetando conexões ou aplicando outras contramedidas. Essa distinção é cobrada no domínio de Arquitetura e Design de Segurança da Security+ (SY0-701), objetivo 3.2, que trata de tecnologias de segurança de rede.

✗ **Por que as outras estão erradas:**

- *São a mesma coisa:* IDS e IPS são tecnologias distintas com funções e posicionamentos diferentes na rede. O IDS é um sistema de detecção passiva, geralmente conectado a uma porta SPAN ou TAP, que analisa cópias do tráfego. O IPS é um sistema de prevenção ativa, instalado em linha (inline) com o fluxo de dados, capaz de bloquear ataques. Afirmar que são a mesma coisa ignora suas diferenças operacionais, de impacto na rede e de resposta a incidentes, além de contrariar definições consagradas em segurança da informação.
- *IDS é de disco; IPS é de rede:* Essa afirmação é incorreta porque ambos podem atuar em rede ou

em host. Existem HIDS (Host-based IDS) e HIPS (Host-based IPS), que monitoram atividades em um único dispositivo, incluindo chamadas de sistema e integridade de arquivos. Da mesma forma, NIDS (Network-based IDS) e NIPS (Network-based IPS) analisam tráfego de rede. A distinção não é entre disco e rede, mas entre detecção passiva e prevenção ativa. A alternativa confunde o escopo de monitoramento com o mecanismo de resposta.

- *IPS só grava log*: Essa descrição se aplica mais a um IDS, que tipicamente registra eventos e emite alertas. O IPS não se limita a gravar logs; sua função principal é bloquear ativamente tentativas de intrusão. Embora muitos IPS também gerem logs para auditoria, sua característica definidora é a capacidade de prevenir ataques em tempo real, tomando ações como descartar pacotes maliciosos ou encerrar sessões. Reduzir o IPS a um mero gravador de logs subestima sua função crítica de proteção ativa.

3) B — DMZ (screened subnet).

✓ **Por que está certa:** A alternativa correta é 'DMZ (screened subnet)'. Uma DMZ (Zona Desmilitarizada), também chamada de sub-rede filtrada (screened subnet), é um segmento de rede isolado que fica entre a rede interna confiável e a rede externa não confiável (como a Internet). Ela hospeda servidores públicos, como web, e-mail, DNS e FTP, que precisam ser acessíveis externamente. O objetivo é que, se um desses servidores for comprometido, o atacante não tenha acesso direto à rede interna, pois há firewalls controlando o tráfego entre a DMZ e a rede interna. O CompTIA Security+ SY0-701, no domínio de Arquitetura e Design (2.2), descreve a DMZ como uma zona de segurança para expor serviços públicos de forma controlada. A questão descreve exatamente essa função: sub-rede isolada que expõe servidores públicos protegendo a rede interna.

✗ **Por que as outras estão erradas:**

- *VLAN de voz*: VLAN de voz é uma rede local virtual dedicada a tráfego de VoIP (voz sobre IP), separando-o dos dados para garantir qualidade de serviço (QoS) e segurança. Ela não é projetada para expor servidores públicos à Internet; pelo contrário, isola o tráfego de voz. Não oferece o isolamento entre rede interna e externa que uma DMZ proporciona. Portanto, não atende ao requisito de proteger a rede interna enquanto expõe serviços públicos.

- *VPN*: VPN (Virtual Private Network) é uma tecnologia que cria um túnel criptografado para transmitir dados de forma segura através de redes não confiáveis, permitindo acesso remoto ou interconexão de filiais. Embora melhore a segurança da comunicação, não é uma sub-rede isolada para hospedar servidores públicos. Uma VPN pode ser usada para acessar a DMZ, mas não substitui a DMZ. A questão pede uma zona de rede que exponha servidores públicos, o que não é a função primária de uma VPN.

- *Intranet*: Intranet é uma rede privada interna que utiliza tecnologias da Internet (como HTTP, FTP) para compartilhar informações dentro de uma organização. Ela é acessível apenas por usuários autorizados e não é exposta ao público externo. Portanto, não serve para hospedar servidores públicos que precisam ser acessados pela Internet. A intranet é o oposto de uma DMZ nesse aspecto: é interna e restrita, não uma zona de exposição controlada.

4) C — Implementar a solução correspondente: NGFW = stateful + app + user + threat intelligence....

✓ **Por que está certa:** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 4.5 (Firewalls): NGFW = stateful + app + user + threat intelligence.

✗ **Por que as outras estão erradas:**

- *Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema*: Viola frontalmente o pilar de Accounting e a rastreabilidade forense. Sem logs, a equipe fica cega para detectar incidentes e quebra normas de conformidade (PCI DSS, ISO 27001).

- *Substituir controles técnicos preventivos por termos de adesão informais*: Termos informais são controles administrativos, dependem exclusivamente da conduta do usuário e não bloqueiam ataques automatizados, injeções ou malwares em tempo de execução.
- *Permitir acesso compartilhado entre administradores com credenciais genéricas*: Destroi a responsabilização individual (Accountability) e o Não-repúdio. Torna impossível comprovar quem realizou alterações críticas ou comandos maliciosos.

5) A — Implementar a solução correspondente: Screened subnet (DMZ): zona entre a internet e a rede interna....

✓ **Por que está certa:** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 4.5 (Firewalls): Screened subnet (DMZ): zona entre a internet e a rede interna.

✗ Por que as outras estão erradas:

- *Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema*: Viola frontalmente o pilar de Accounting e a rastreabilidade forense. Sem logs, a equipe fica cega para detectar incidentes e quebra normas de conformidade (PCI DSS, ISO 27001).
- *Substituir controles técnicos preventivos por termos de adesão informais*: Termos informais são controles administrativos, dependem exclusivamente da conduta do usuário e não bloqueiam ataques automatizados, injeções ou malwares em tempo de execução.
- *Permitir acesso compartilhado entre administradores com credenciais genéricas*: Destroi a responsabilização individual (Accountability) e o Não-repúdio. Torna impossível comprovar quem realizou alterações críticas ou comandos maliciosos.

6) A — Implementar a solução correspondente: 'firewall that inspects traffic at the application layer'=NGFW/WAF....

✓ **Por que está certa:** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 4.5 (Firewalls): 'firewall that inspects traffic at the application layer'=NGFW/WAF.

✗ Por que as outras estão erradas:

- *Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema*: Viola frontalmente o pilar de Accounting e a rastreabilidade forense. Sem logs, a equipe fica cega para detectar incidentes e quebra normas de conformidade (PCI DSS, ISO 27001).
- *Substituir controles técnicos preventivos por termos de adesão informais*: Termos informais são controles administrativos, dependem exclusivamente da conduta do usuário e não bloqueiam ataques automatizados, injeções ou malwares em tempo de execução.
- *Permitir acesso compartilhado entre administradores com credenciais genéricas*: Destroi a responsabilização individual (Accountability) e o Não-repúdio. Torna impossível comprovar quem realizou alterações críticas ou comandos maliciosos.

7) D — Implementar a solução correspondente: 'firewall moderno que reconhece apps e aplica regra a usuário'=NGFW.....

✓ **Por que está certa:** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 4.5 (Firewalls): 'firewall moderno que reconhece apps e aplica regra a usuário'=NGFW..

✗ Por que as outras estão erradas:

- *Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema*: Viola frontalmente o pilar de Accounting e a rastreabilidade forense. Sem logs, a equipe fica cega para detectar incidentes e quebra normas de conformidade (PCI DSS, ISO 27001).
- *Substituir controles técnicos preventivos por termos de adesão informais*: Termos informais são controles administrativos, dependem exclusivamente da conduta do usuário e não bloqueiam ataques automatizados, injeções ou malwares em tempo de execução.

- *Permitir acesso compartilhado entre administradores com credenciais genéricas:* Destroi a responsabilização individual (Accountability) e o Não-repúdio. Torna impossível comprovar quem realizou alterações críticas ou comandos maliciosos.

8) D — Implementar a solução correspondente: NGFW = stateful + app + user + threat intelligence....

✓ **Por que está certa:** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 4.5 (Firewalls): NGFW = stateful + app + user + threat intelligence.

✗ **Por que as outras estão erradas:**

- *Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema:* Viola frontalmente o pilar de Accounting e a rastreabilidade forense. Sem logs, a equipe fica cega para detectar incidentes e quebra normas de conformidade (PCI DSS, ISO 27001).
- *Substituir controles técnicos preventivos por termos de adesão informais:* Termos informais são controles administrativos, dependem exclusivamente da conduta do usuário e não bloqueiam ataques automatizados, injeções ou malwares em tempo de execução.
- *Permitir acesso compartilhado entre administradores com credenciais genéricas:* Destroi a responsabilização individual (Accountability) e o Não-repúdio. Torna impossível comprovar quem realizou alterações críticas ou comandos maliciosos.

9) C — Implementar a solução correspondente: Screened subnet (DMZ): zona entre a internet e a rede interna....

✓ **Por que está certa:** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 4.5 (Firewalls): Screened subnet (DMZ): zona entre a internet e a rede interna.

✗ **Por que as outras estão erradas:**

- *Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema:* Viola frontalmente o pilar de Accounting e a rastreabilidade forense. Sem logs, a equipe fica cega para detectar incidentes e quebra normas de conformidade (PCI DSS, ISO 27001).
- *Substituir controles técnicos preventivos por termos de adesão informais:* Termos informais são controles administrativos, dependem exclusivamente da conduta do usuário e não bloqueiam ataques automatizados, injeções ou malwares em tempo de execução.
- *Permitir acesso compartilhado entre administradores com credenciais genéricas:* Destroi a responsabilização individual (Accountability) e o Não-repúdio. Torna impossível comprovar quem realizou alterações críticas ou comandos maliciosos.

10) D — Implementar a solução correspondente: 'firewall that inspects traffic at the application layer'=NGFW/WAF....

✓ **Por que está certa:** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 4.5 (Firewalls): 'firewall that inspects traffic at the application layer'=NGFW/WAF.

✗ **Por que as outras estão erradas:**

- *Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema:* Viola frontalmente o pilar de Accounting e a rastreabilidade forense. Sem logs, a equipe fica cega para detectar incidentes e quebra normas de conformidade (PCI DSS, ISO 27001).
- *Substituir controles técnicos preventivos por termos de adesão informais:* Termos informais são controles administrativos, dependem exclusivamente da conduta do usuário e não bloqueiam ataques automatizados, injeções ou malwares em tempo de execução.
- *Permitir acesso compartilhado entre administradores com credenciais genéricas:* Destroi a

responsabilização individual (Accountability) e o Não-repúdio. Torna impossível comprovar quem realizou alterações críticas ou comandos maliciosos.